Abbott

QRC EDUCATIONAL SESSION

System Risk Classification(SRC)

September | 2024

Proprietary and confidential — do not distribute

SYSTEM RISK CLASSIFICATION

Topics of Discussion

- ❑ System Risk Classification template – BTSQC09.05-A Overview
- ❑ SRC Request Intake Process with the Roles and Responsibilities (approvers)
- ❑ Examples
- ❑ Conversion to ProcessX
- ❑ Reference Information
- ❑ Q&A

Proprietary and confidential — do not distribute

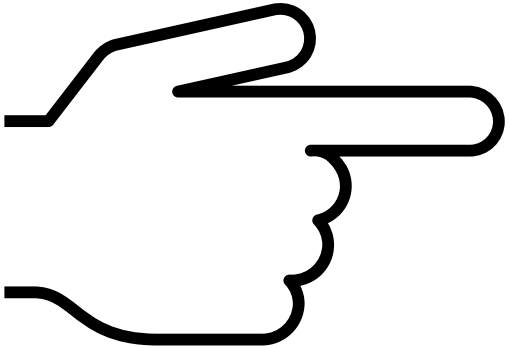
Overview

System Risk Classification

BTSQC09.05 –A - WHAT IS A SYSTEM RISK CLASSIFICATION?

- A System Risk Classification is a document that gives an overall summary of the system. It allows for a review of Abbott's Intended Use and setup in one view. The SRC is one of the first deliverables of BTSQC09.05.
- It is a summary view of the details from a system perspective. The intended use should include all interfaces and the Divisions that use the system as well as the owning Division.
- The SRC must:
  - Identify ALL applicable regulations
  - Determine if the system is Quality versus NON-Quality and if there is direct or indirect impact to the patient or product.
  - Identify the type of data that is stored in the system or the type of data that is passed through the system.
  - Be reviewed by any applicable SMEs.

Step One: Initiation



Initiate System Risk Classification (SRC) in applicable SLC repository, in alignment with the DLM.

RESPONSIBLE: *Business Process Owner*

Also make sure the Business Impact Assessment is in progress. ***ALL*** *systems must have an SRC, DLM* and BIA*.*

NOTE: **See appropriate SOP for in-scope application requirements.*

Proprietary and confidential — do not distribute

SRC Overview

SYSTEM RISK CLASSIFICATION (SRC) BTSQC09.05-A

System Risk Classification requires the following assessments, when applicable: TVRM and CVRM, Regulatory Requirements, Data, and mandatory Data Protection Controls.

- BTSQC09.05-A – *System Risk Classification*(SRC)
- TVRM and CVRM –Vendor Risk Assessment for Technology and Cybersecurity
- Regulatory Requirements – Identify any Quality, Privacy, PCI or SOX or any other regulation that is needed to confirm the SRC assessment.

System Risk Classification

2.0 System Information

2.1 System Name

Formal System Name and Acronym/Abbreviation:

2.2 System Description

System Description

Intended Use

This is a short blurb that explains what business process is being implemented for Abbott.

This is very specific to HOW Abbott is using the SYSTEM and make sure you list upstream and downstream interfaces

System Risk Classification

2.3 Most Severe Consequence

Document the most severe consequence resulting from a failure. This is not referring to a BIA/DR failure. details of risk see AQ0905.A:

Select the failure: Choose an item.

Describe the response below (be sure to include the consequences of the failure):

Describe the most severe possible impact to patient, product, or data. This impact should [illegible] with the highest criticality requirement in the system.

e.g Consequence can be data loss; a security failure, security breach, quality data function failure, regulatory functional failure, wrong release of batches; that directly or indirectly affect Patient Safety or Health. .

Failure should be aligned with the regulatory assessment . Think about this from the perspective would Abbott end up in the News from a failure in the system. Abbott shipped bad product and had a recall? This is not a system availability failure. This is a regulatory function failure.

System Risk Classification

3.0 Technical Information

System Type: Choose an item.

Describe if "Other":	**N/A**

Application Type (Complexity): Choose an item.

Internet Facing: Choose an item.

Hosting Type: Choose an item.

3.1 Vendors

A Vendor Risk Assessment is required for all purchased regulated applications and Externally Hosted regulated applications per SOP BTSQC11.01 IT Vendor Risk Management Process. List all vendors supporting this application including purchased products.

Vendor Name	Type of Supplier	Assessment Completed	Vendor Assessment Storage Location and Assessment ID
		☐ Yes ☐ No	Stored with VRA Group
		☐ Yes ☐ No	Stored with VRA Group

NOTE: Most current vendor assessment is stored as indicated in the table above. Approvers should confirm the vendor has been assessed for the same risks identified in this document.

Application
Computerized Tool
Website
Other

COTS
Configurable
Custom Developed
Configured and Custom Developed
COTS and Configurable
Customized COTS
COTS, Custom Developed & Configurable

Yes Or NO. This is asking if it External?

On Prem
Cloud SaaS
Cloud PaaS
Cloud IaaS

TVRM and/or CVRM approval Number must be provided prior to approval

System Risk Classification

These questions guide you through to identify if THE SYSTEM impacts any quality regulations

4.0 Quality System Regulatory Assessment

The following questions are used to determine whether the intended use of the application or system requires compliance with federal and/or international GxP (Quality) regulations. A "Yes" answer to one or more of the questions in each section indicates that the application or system is used to make quality decisions or is used to meet the quality system regulations. More than one type of quality system use may be applicable.

4.1 GxP (Quality) Regulatory Assessment

Note: If any elements of the Quality System are checked yes, the application is considered GxP. Comments are suggested when Yes is selected. When in doubt, open the corresponding Quality System Policy listed with the question.

#	Answer each numbered question with a Yes or No as they apply.	Comments
1.	**Does the system support Quality Management? (AQ01.A)** ☐ Yes ☐ No	N/A
a.	Does the application or system affect regulatory submission/registration?	
b.	Does the application or system perform calculations/algorithms that will support a regulatory submission/registration?	
c.	Does the application or system produce, gather or report information used to support Quality System decisions (e.g., metrics, trending, etc.)?	
d.	Does the system support processes to establish Quality System, management responsibilities and authority, quality planning, quality audits, management reviews and continuous improvement of the Quality System?	
2.	**Does the system support Personnel? (AQ02.A)** ☐ Yes ☐ No	N/A
a.	Does the application or system maintain training requirements and/or records?	
b.	Does the system maintain personnel qualifications?	
c.	Does the system control access to quality systems? (i.e., ESAM)	

Proprietary and confidential — do not distribute

System Risk Classification

#	Answer each numbered question with a Yes or No as they apply.	Comments
4.	**Does the system support Complaints & Product Actions? (AQ04.A)** ☐ Yes ☐ No	N/A
a.	Is the application or system used for collecting, monitoring, signaling, assessing and evaluating adverse effects information from healthcare providers and patients (i.e., pharmacovigilance)?	
b.	Does the application or system maintain records and/or approvals addressing the identification, evaluation, segregation or disposition of nonconforming products?	
c.	Can the application or system be used for product/sample recall, reconciliation, product history, product-related customer complaints?	
d.	Does the application or system maintain records of the initiation, review, evaluation or investigation of complaints?	
5.	**Does the system support Documentation & Change Control? (AQ05.A)** ☐ Yes ☐ No	N/A
a.	Does the application or system control review approval and/or distribution of quality system documents?	

If the system has the possibility of taking in a complaint or the start of a complaint, then the answer to this question is YES i.e. Contact us page with a free text field or voicemail

System Risk Classification

	characteristics during production?	
g.	Does the application or system maintain the Device Master Records or the Device History Records for products?	
h	Does the application or system provide statistical rationale for the establishment of sampling plans?	
i.	Does the application or system establish the use of statistical techniques for verifying the acceptability of process capability and product characteristics?	
14.	**Does the system support Packaging and Labeling (AQ14.A) or Promotional Material Controls? (AQ14A.A)** ☐ **Yes** ☒ **No**	N/A
a.	Does the application or system automate the label and/or Instructions for Use (IFU) and/or product insert (PI) printing, inspection or accountability in any part of the manufacturing/distribution process including in process, finished product, and distribution control labeling?	
b.	Does the application or system support coding of materials, formulated products or package components (i.e., labels and label identification manufacturing lot number, serial number, expirati date, UDI, etc.)?	
c.	Does the system, website site, mobile application or externally facing application contain labels, labeling, Instructions for Use, product insert information, updates or supplements to IFU and/or PI, promotional materials, product ingredient and/or disease treatment information?	
15.	**Does the system support Laboratory Controls? (AQ15.A)** ☐ **Yes** ☒ **No**	N/A
a.	Is the application or system used to support product stability studies?	
16.	**Does the system support Distribution, Installation and Servicing Controls? (AQ16.A)** ☐ **Yes** ☒ **No**	N/A
a.	Does the application or system maintain records of installations for products that require installation?	
b.	Does the application or system maintain records or control content of shipping addresses for product distribution?	
c.	Does the application or system maintain records of distribution, such as who is to receive product, how much, when, and what lot/batch/etc.?	

Content displayed to customers that are approved through MLR need quality controls to ensure the content is current and accurate

System Risk Classification

Is the system regulated for GxP (Quality)? Choose an item.

Yes or No

If "Yes" is the response to any of the Quality System Elements, the system is GxP Applicable, then continue to complete section 4.2 GxP Risk Criticality Questionnaire.

If "No" is the response to all questions, skip ahead to 5.0 Privacy.

4.2 GxP Risk Criticality Questionnaire

(Only applicable if there is a Yes from 4.1 above)

Only do this section if 4.1 is YES

Answer all questions with Yes or No and explain the answer, as necessary to determine the criticality (Critical, Non-Critical, Non-Quality).

Proprietary and confidential — do not distribute

System Risk Classification

#	Questions	Yes/No	Comment, Explanation, and or Reference
1.	Does the system have a DIRECT impact on patient, personnel, public and/or product safety, product quality, efficacy, and/or performance?	☐ Yes ☐ No	N/A
2.	Does the system have quality data that is analyzed, retrieved, manipulated, stored, reported and/or maintained that DIRECTLY affect patient, personnel, public and/or product safety, product quality, efficacy, and/or performance? Consideration must be given to missing, incorrect or changed data where it may result in inappropriate decision or action.	☐ Yes ☐ No	N/A
3.	Does the system have an INDIRECT impact on patient, personnel, public and/or product safety, product quality, efficacy and/or performance?	☐ Yes ☐ No	N/A
4.	Does the system have quality data that is analyzed, retrieved, manipulated, stored, reported and/or maintained that INDIRECTLY affect patient, personnel, public and/or product safety, product quality, efficacy, and/or performance? Consideration must be given to missing, incorrect or changed data where it may result in inappropriate decision or action?	☐ Yes ☐ No	N/A
5.	Does the system have: • Functionality that provides for compliance with governmental regulations not classified as "critical" above, and/or • Records stored in this system required to meet regulatory requirements?	☐ Yes ☐ No	N/A

Based on the responses to the questions in the previous section, determine the GxP Risk Cla

GxP (Quality) Risk Classification	Responses to 5 Risk Classification Questio (above)
Critical (High)	If "Yes" is the response to questions 1, 2 .
Non-Critical (Medium)	If "No" is the response to questions 1, 2 and "Yes" is the response to questions 3, 4 or 5.
Non-Quality (N/A)	If "No" is the response to questions 1, 2, 3, 4, or 5

What is the GxP Risk Classification? Choose an item.

Remember Direct or Indirect impact to the Product or Patient

Critical means DIRECT

NON Critical means INDIRECT

System Risk Classification

5.0 Privacy Regulatory Assessment

This section assesses General Data Protection.
Sensitivity Levels are documented within I1-05 Information Classification Policy and include:

- Does Not Apply (No Personal Information)
- Privacy Public
- Privacy Internal Use Only
- Privacy Restricted (Confidential)
- Privacy Highly Restricted (Secret)

Note: Any data within a system classified as Privacy Restricted or Privacy Highly Restricted will define the system as Regulated for Privacy with the Risk Level of "Critical". Systems classified as Privacy Internal Use Only, Privacy Public or Does Not Apply (No Personal Information), are to be marked as Non-Regulated for Privacy in section 6.0.

Determine if the system will collect, process, or retain any information about a person.

	Questions	Comment, Explanation, and or Reference
1.	Does the system contain any information about a person? If Yes continue with question 2.	Choose an item.
2.	2a. Describe/List the most sensitive data. (For example: patient health data, customer contact information, employee performance data, etc.).	
	2b. Identify the system Privacy Data Sensitivity level	Choose an item.
If 2b is Restricted or Highly Restricted, complete 3 and 4; otherwise continue to section 5.1.		
3.	What is the intended geographic scope of the personal information? (Where do the data subjects reside? For example, European Union, United States, Brazil, China, Russia, Global, etc.)	
4.	GDPR (General Data Protection Regulation) applicability: Does the system collect, process, transmit or store Restricted or Highly Restricted personal information of European Union residents?	Choose an item.

When there is Privacy Data the Privacy SME should guide the answers to these Questions

System Risk Classification

These questions are to help identify what regulations apply

5.1 Payment Card Industry (PCI) Regulatory Assessment

The Risk Level associated with PCI is "Critical". If the system is involved in storing or transferring the payment card user-session to a 3rd party during checkout - the system affects the overall security of the transaction and is in scope for PCI. See CFM 0075 Payment Card Industry (PCI) or 4-035 IT Payment Card Industry Compliance (PCI) for more information. Any system Regulated for PCI is regulated for Privacy.

Does the system facilitate, store or process payment card information? (Yes / No) Choose an item.

5.2 HIPAA Regulatory Assessment

Health Insurance Portability and Accountability Act (HIPAA). The Risk Level associated with HIPAA is "Critical". Any system Regulated for HIPAA is regulated for Privacy. Consult with your division privacy officer.

Is the system regulated under HIPAA? (Yes / No) Choose an item.

5.3 Sarbanes Oxley (SOX) Regulatory Assessment

Systems with material impact on external financial reporting systems and within scope of Sarbanes-Oxley Act. The Risk Level associated with SOX is "Critical". Consult with the Sox program Manager, Within the Cybersecurity Team for more information if needed.

Is the system regulated for SOX? (Yes / No) Choose an item.

System Risk Classification

6.0 System Classification

Based on the regulatory evaluations performed within sections 4 – 5 and any other applicable regulatio
identified below, select the classification levels which apply for the system. **Check all that apply:**

Regulation	Classification Level
☐ Regulated	
☐ GxP (Quality)	Choose an item.
☐ Privacy	Choose an item.
☐ GDPR (European Union Privacy)	
☐ PCI	
☐ HIPAA	
☐ Sarbanes-Oxley (SOX)	
☐ Other regulation(s): _____	
☐ Non-Regulated	

This is a summary of form.

Make sure you specify any other regulation that will be applied

System Risk Classification

7.0 Sensitivity Classification

Business Sensitivity Classification

Systems that contain Structured Data must identify the Business Sensitivity Classification of the data processed by the system so that appropriate security controls can be applied. The Business Sensitivity Classification must match the classification in the Data Lifecycle Management (DLM) assessment. Refer to Policy I1-05, Information Classification Policy for additional information.

Select the highest Business Sensitivity Classification for the data processed by this system:	Choose an item.

Data Sensitivity Classification

Select the highest assigned data classification level between Privacy Data Sensitivity (section 5.0, 2b) and Business Sensitivity Classification (section 7.0).	Choose an item.

Systems with sensitivity classification as Restricted or Highly Restricted are required to complete a Data Protection Plan.

This is to help identify what kind of data is in the system and should be in alignment with the DLM

SRC Summary

SYSTEM RISK CLASSIFICATION (SRC) BTSQC09.05-A

A System Risk Classification is a document that gives an overall summary of the system. The System Risk Classification (SRC) and Data Protection Plan (DPP) documents cover data classification and protection of Abbott's data through the implementation of security and privacy controls.

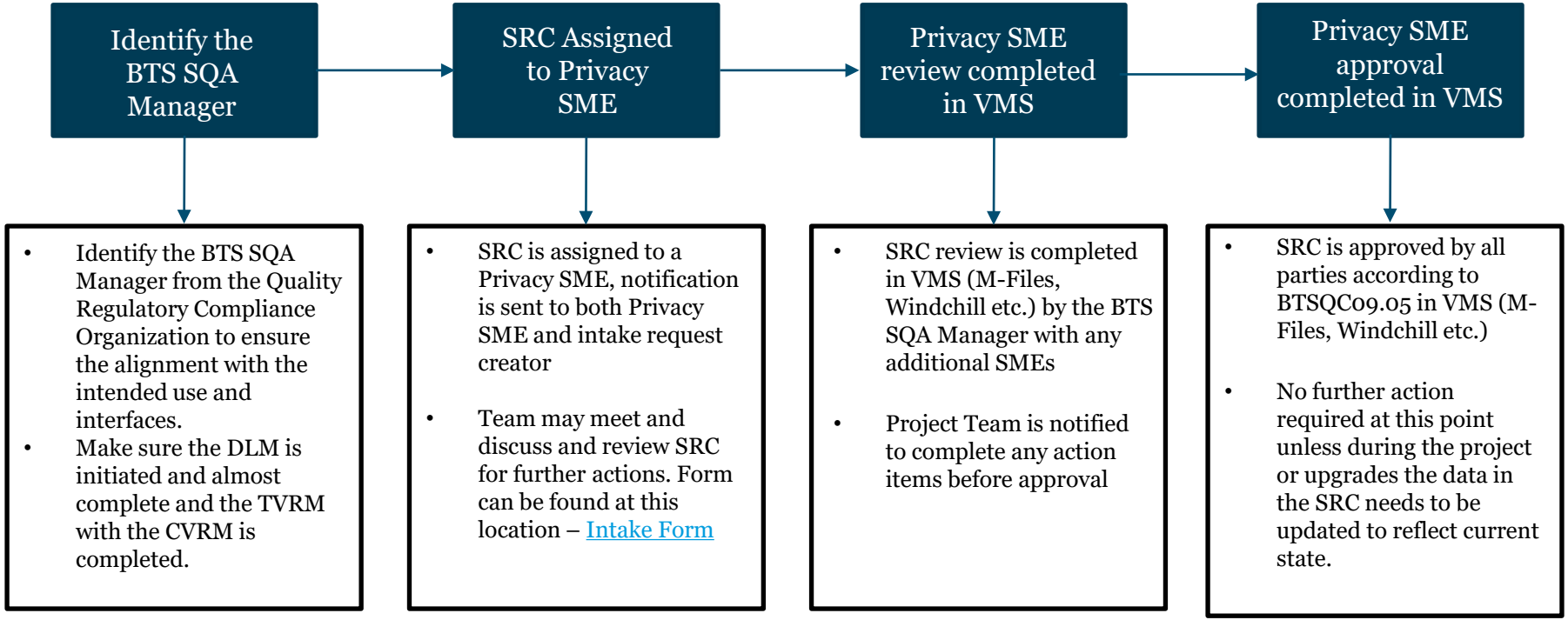
NOTE: System Risk Classification (SRC) template will be digitized as part of ProcessX Project, Q4 2024. The word template will remain until all projects adopt the digitization.

PROCESSX: A regulated workflow automation application installed on the ServiceNow Platform. ProcessX digitizes and streamlines System Life Cycle (SLC) deliverables while ensuring compliance through related digital records and built-in controls.

SRC Request Intake Process

SRC Request Intake Process

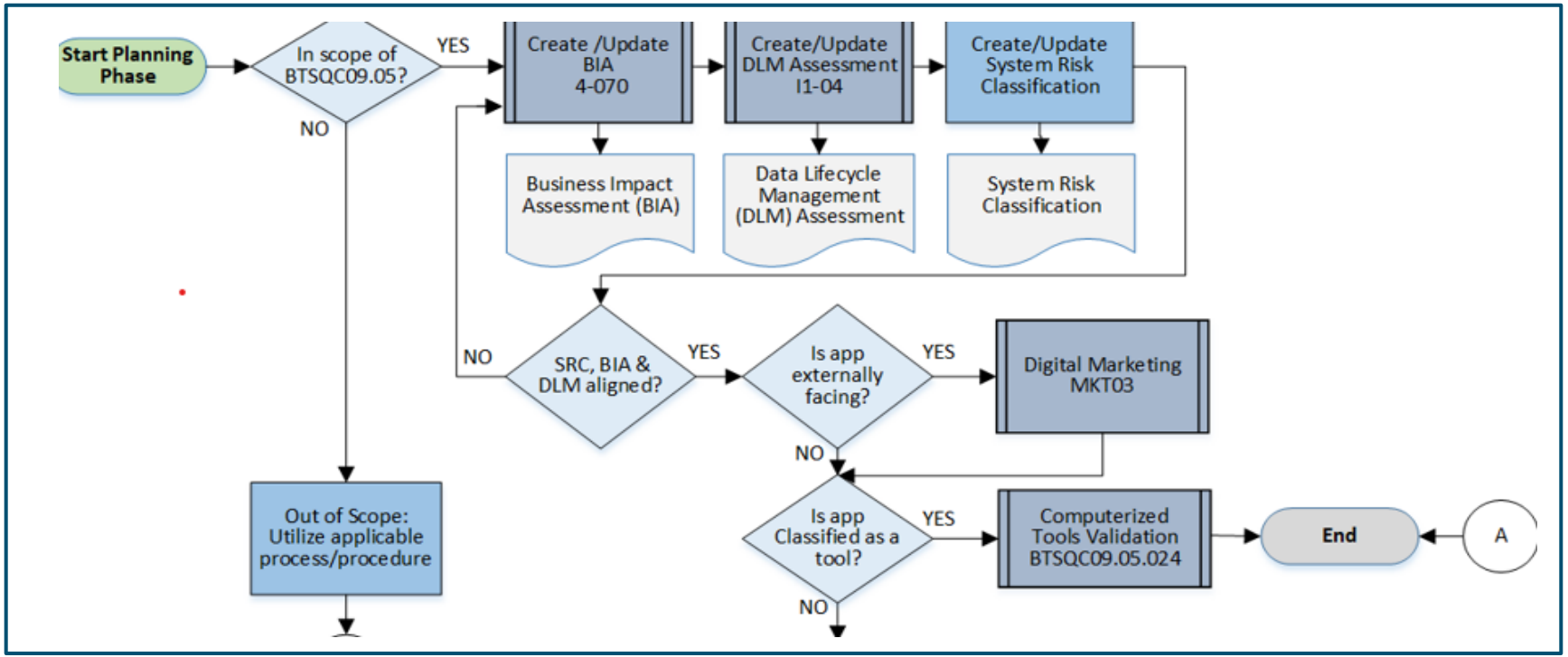
SYSTEM RISK CLASSIFICATION(SRC) - PROCESS FLOW



Proprietary and confidential — do not distribute

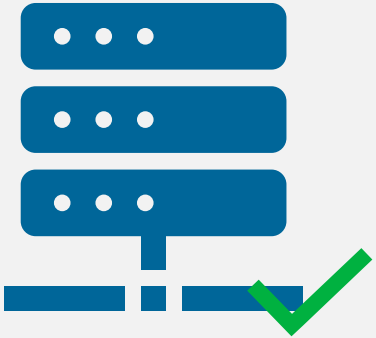
System Risk Classification BTSQC09.05-A

SLC DELIVERABLE – PLANNING PHASE



SRC Data Overview

DATA CLASSIFICATION



Data Classification starts by completing a SRC to determine the intended use of the application as well as privacy sensitivity and DLM to determine business sensitivity. Data Classification is the highest of either business or privacy sensitivity and is recorded in the System Risk Classification (SRC).

For more information on Business and Privacy Sensitivity Classifications, please refer to I1-05, Information Classification Policy.

- BTSQC09.05-A - System Risk Classification (SRC)
- DLM Assessment - Data Lifecycle Management (DLM)
- Data Sensitivity - The higher of business sensitivity and privacy sensitivity

Roles & Responsibilities

SLC documents are approved by a multi-disciplinary team (e.g., business process owner, system owner, architect) and includes representatives with expertise in relevant governing regulations (e.g., GxP, Sarbanes-Oxley Act, Data privacy, Cybersecurity, etc.). In addition, for quality-related systems, a quality representative must review and approve key deliverables.

Business Process Owner

- Defines the Intended Use
- Identifies any system that is integrated with THE System
- Ensures the applicable regulations are identified
- Verifies the vendor assessments (when applicable) are complete with the vendor management team and the cybersecurity team

IT System Owner

- Identifies the platform that is utilized
- Identifies any system that is integrated with THE System
- Ensures the applicable regulations are identified

Example

Example: Intended Use

The ADC Unity application (ADC Customer Service system) is a global omni-channels (CTI, Email, Web, Self Service Webform, Social, Web Callback, C360, Live Chat) contact registration application that provides agents across Abbott Diabetes Care's (ADC) Customer Service organization functionality to record, manage, and track customer interactions, troubleshoot and resolve customer cases and complaints.

The Unity system also allows the ADC customer service organization to capture information required for post-market surveillance and investigations. Unity is the primary input of customer complaint cases and is integrated with Luna using TIBCO as middleware for complaint cases.

Unity interfaces with OneStep to enable troubshooting guide (TSG) publication.

Unity interfaces with both Gravity (Magento) (EMEA) and EC3 (US) to synchronize customer account information between systems. Unity pushes order information to Gravity (Magento) for order fulfillment (EMEA).

Unity interfaces with Foundever (external vendor) via Informatica to send Blood Glucose Monitor (BGM) order information for UK and Germany.

OwnBackup is a third party managed application used for backup/restore & archive/unarchive for the Unity records.

Example

OwnBackup is a third party managed application used for backup/restore & archive/unarchive for the Unity records.

InCountry is a third party managed application used for data residency & regulatory requiring the PII data to be stored locally in the countries like Russia.

Cloudingo is a third party managed application used for data cleansing and de-duplication.

Unity interfaces with Foundever and Five9 call centers to use CTI features.

Document ID: BTSQC09.05-A, Version10 Page 4 of 19

Example

3.1 System Type

Determine and document the type of system.Choose an Item:

- ☒ Application
- ☐ Computerized Tool
- ☒ Website
- ☐ Middleware
- ☐ Spreadsheet
- ☐ Other: [N/A *or (Other – then list here (e.g., Mobile Apps))*]

3.2 Complexity

Determine and document complexity of the application. Check all that apply:

- ☒ COTS (Commercial-Off-The-Shelf)
- ☒ Configurable
- ☒ Custom

3.3 Hosting and Data Arrangement

Identify the hosting arrangement for the system or components. Check all that apply:

- ☐ Internal: Systems or components that are hosted on Abbott infrastructure
- ☒ External: Systems or components that are hosted on a third party's infrastructure – check all that apply
  - ☒ Software as a Service (SaaS)
  - ☒ Platform as a Service (PaaS
  - ☐ Infrastructure as a Service (IaaS)
  - ☒ Internet Facing (system has an external facing interface)
  - ☐ Other – then list here _____

Example

3.4 Vendors

A Vendor Risk Assessment is required for all purchased regulated applications or Externally Hosted regulated applications per SOP BTSQC11.01 IT Vendor Risk Management Process. List all vendors supporting this application including purchased products.

Vendor Name	Type of Supplier	Assessment Completed	Vendor Assessment Storage Location and Assessment ID
Salesforce.com	**Hosting**	☒ Yes ☐ No	Vendor assessment is retained by the BTS vendor group. M-Files reference number is VRM00909.
Salesforce.com	**Software**	☒ Yes ☐ No	Vendor assessment is retained by the BTS vendor group. M-Files reference number is VRM00909.
Sitel (Foundever)	**Other - Describe Vendor**	☒ Yes ☐ No	Vendor assessment is retained by the BTS vendor group. M-Files reference number is VRM00950
OwnBackUp	**Software**	☒ Yes ☐ No	Stored with VRA Group. ID: ENG-4841 Storage Location: Archer
Cloudingo	**Software**	☒ Yes ☐ No	Stored with VRA Group. ID: ENG-6626 Storage Location: Archer
Five9	**Software**	☒ Yes ☐ No	Stored with VRA Group. VRM02097 Storage Location: M-Files
MaritzCX Research (InMoment)	**Software**	☒ Yes ☐ No	Stored with VRA Group. ID: ENG-6808

Example

		☐ No	ID: ENG-4851 Storage Location: Archer

NOTE: Most current vendor assessment is stored as indicated in the table above. Approvers should confirm the vendor has been assessed for the same risks identified in this document.

4.0 Quality System Regulatory Assessment

The following questions are used to determine whether the intended use of the application or system requires compliance with federal and/or international GxP (Quality) regulations. A "Yes" answer to one or more of the questions in each section indicates that the application or system is used to make quality decisions or is used to meet the quality system regulations. More than one type of quality system use may be applicable.

4.1 GxP (Quality) Regulatory Assessment

Note: If any elements of the Quality System are checked yes, the application is considered GxP. Comments are suggested when Yes is selected. When in doubt, open the corresponding Quality System Policy listed with the question.

#	Answer each numbered question with a Yes or No as they apply.	Comments
1.	**Does the system support Quality Management? (AQ01.A)** ☒ Yes ☐ No	System supports product complaint registration.
a.	Does the application or system affect regulatory submission/registration?	
b.	Does the application or system perform calculations/algorithms that will support a regulatory submission/registration?	
c.	Does the application or system produce, gather or report information used to support Quality System decisions (e.g., metrics, trending, etc.)?	
d.	Does the system support processes to establish Quality System, management responsibilities and authority, quality planning, quality audits, management reviews and continuous improvement of the Quality System?	
2.	**Does the system support Personnel? (AQ02.A)** ☐ Yes ☒ No	N/A
a.	Does the application or system maintain training requirements and/or records?	

a.	Does the application or system maintain records of product conformance or nonconformance to acceptance criteria throughout its distribution and lifecycle?	
b.	Does the application or system maintain records for the analysis, investigation, verification, and implementation of corrective or preventative actions?	
4.	**Does the system support Complaints & Product Actions? (AQ04.A)** ☒ Yes ☐ No	System supports product complaint registration.
a.	Is the application or system used for collecting, monitoring, signaling, assessing and evaluating adverse effects information from healthcare providers and patients (i.e., pharmacovigilance)?	
b.	Does the application or system maintain records and/or approvals addressing the identification, evaluation, segregation or disposition of nonconforming products?	
c.	Can the application or system be used for product/sample recall, reconciliation, product history, or product-related customer complaints?	
d.	Does the application or system maintain records of the initiation, review, evaluation or investigation of complaints?	
5.	**Does the system support Documentation & Change Control? (AQ05.A)** ☐ Yes ☒ No	N/A
a.	Does the application or system control review approval and/or distribution of quality system documents?	
b.	Does the application or system maintain records of changes to quality system documents?	
c.	Does the application or system store quality system documents for archival?	
6.	**Does the system support Buildings, Facilities and Utilities? (AQ06.A)** ☐ Yes ☒ No	N/A
a.	Where environmental conditions can have an adverse effect on product quality, does the application or system, control these environmental conditions?	
b	Where access is controlled by unauthorized individuals to buildings, facilities or utilities, can this potentially impact product quality?.	
7.	**Does the system support Equipment? (AQ07.A)** ☐ Yes ☒ No	N/A
a.	Does the application or system maintain records for the calibration of equipment or for the standards used in calibration of equipment used in production?	
b.	Does the application or system maintain records of maintenance, cleaning or inspection of equipment used in production?	

Proprietary and confidential — do not distribute

Example

4.2 GxP Risk Criticality Questionnaire

(Only applicable if there is a Yes from 4.1 above)

Answer all questions with Yes or No and explain the answer, as necessary to determine the criticality (Critical, Non-Critical, Non-Quality).

#	Questions	Yes/No	Comment, Explanation, and or Reference
1.	Does the system have a DIRECT impact on patient, personnel, public and/or product safety, product quality, efficacy, and/or performance?	☐ Yes ☒ No	N/A
2.	Does the system have quality data that is analyzed, retrieved, manipulated, stored, reported and/or maintained that DIRECTLY affect patient, personnel, public and/or product safety, product quality, efficacy, and/or performance? Consideration must be given to missing, incorrect or changed data where it may result in inappropriate decision or action.	☒ Yes ☐ No	ADC Unity system is used to register complaints for all of it's products worldwide. The ADC Unity application will allow agents across Abbott Diabetes Care's (ADC) Customer Service organization to record, manage, and track customer interactions, troubleshoot and resolve customer cases and complaints, and capture information required for post-market surveillance and investigations.

Example

Based on the responses to the questions in the previous section, determine the GxP Risk Classification:

GxP (Quality) Risk Classification	Responses to 5 Risk Classification Questions (above)
Critical (High)	If "Yes" is the response to questions 1, 2 .
Non-Critical (Medium)	If "No" is the response to questions 1, 2 and "Yes" is the response to questions 3, 4 or 5.
Non-Quality (N/A)	If "No" is the response to questions 1, 2, 3, 4, or 5

What is the GxP Risk Classification? **CRITICAL**

5.0 Privacy Regulatory Assessment

This section assesses General Data Protection.
Sensitivity Levels are documented within I1-05 Information Classification Policy and include:

- Does Not Apply (No Personal Information)
- Privacy Public
- Privacy Internal Use Only
- Privacy Restricted (Confidential)
- Privacy Highly Restricted (Secret)

Note: Any data within a system classified as Privacy Restricted or Privacy Highly Restricted will define the system as Regulated for Privacy with the Risk Level of "Critical". Systems classified as Privacy Internal Use Only, Privacy Public or Does Not Apply (No Personal Information), are to be marked as Non-Regulated for Privacy in section 6.0.

Determine if the system will collect, process, or retain any information about a person.

	Questions	Comment, Explanation, and or Reference
1.	Does the system contain any information about a person? If Yes continue with question 2.	**YES**
2.	2a. Describe/List the most sensitive data. (For example: patient health data, customer contact information, employee performance data, etc.).	**Name, address, Date of Birth, email, Age, Gender, Language Preference and phone Numbers, Race, Ethnicity, PHI and Social handle ID.**
	2b. Identify the system Privacy Data Sensitivity level	**Privacy Highly Restricted**
If 2b is Restricted or Highly Restricted, complete 3 and 4; otherwise continue to section 5.1.		

Example

	Questions	Comment, Explanation, and or Reference
3.	What is the intended geographic scope of the personal information? (Where do the data subjects reside? For example, European Union, United States, Brazil, China, Russia, Global, etc.)	**Global (including European Union, United States, Brazil, China, Russia)**
4.	GDPR (General Data Protection Regulation) applicability: Does the system collect, process, transmit or store Restricted or Highly Restricted personal information of European Union residents?	**Yes: System is in scope of GDPR**

5.1 Payment Card Industry (PCI) Regulatory Assessment

The Risk Level associated with PCI is "Critical". If the system is involved in storing or transferring the payment card user-session to a 3rd party during checkout - the system affects the overall security of the transaction and is in scope for PCI. See CFM 0075 Payment Card Industry (PCI) or 4-035 IT Payment Card Industry Compliance (PCI) for more information. Any system Regulated for PCI is regulated for Privacy.

Does the system facilitate, store or process payment card information? (Yes / No) **NO**

5.2 HIPAA Regulatory Assessment

Health Insurance Portability and Accountability Act (HIPAA). The Risk Level associated with HIPAA is "Critical". Any system Regulated for HIPAA is regulated for Privacy. Consult with your division privacy officer.

Is the system regulated under HIPAA? (Yes / No) **YES**

5.3 Sarbanes Oxley (SOX) Regulatory Assessment

Systems with material impact on external financial reporting systems and within scope of Sarbanes-Oxley Act. The Risk Level associated with SOX is "Critical". Consult with the Sox program Manager, Within the Cybersecurity Team for more information if needed.

Is the system regulated for SOX? (Yes / No) **NO**

Example

6.0 System Risk Classification

Based on the regulatory evaluations performed within sections 4 – 5 and any other applicable regulation identified below, select the classification levels which apply for the system. **Check all that apply:**

Regulation	Classification Level
☒ Regulated	
☒ GxP (Quality)	Critical
☒ Privacy	Critical
☒ GDPR (European Union Privacy)	Critical
☐ PCI	Choose an item.
☒ HIPAA	Critical
☐ Sarbanes-Oxley (SOX)	Choose an item.
☒ Other regulation(s): Data Localization (Russia, Japan, China)	Critical
☐ Non-Regulated	

System Risk Classification (Critical / Non-Critical / Non-Regulated)

Identify the highest risk classification for all regulations applicable to the system:	CRITICAL

7.0 Sensitivity Classification

Business Sensitivity Classification

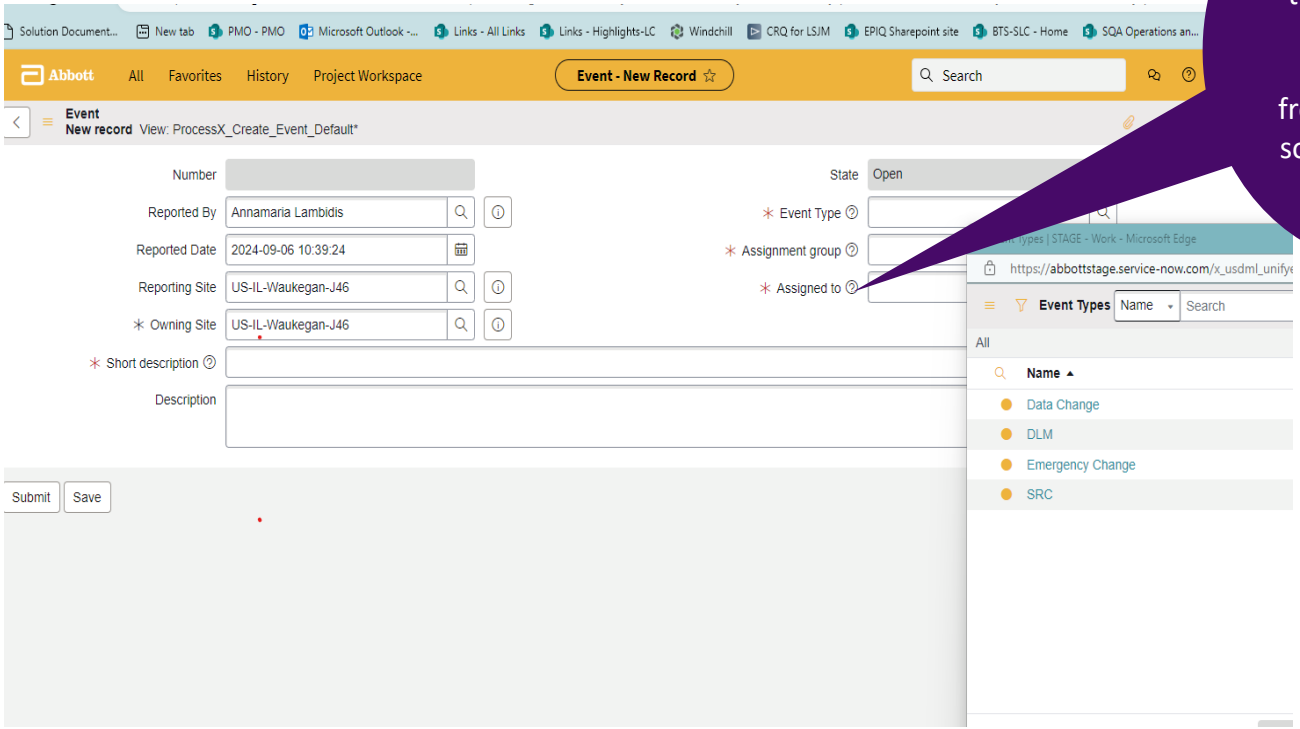
Systems that contain Structured Data must identify the Business Sensitivity Classification of the data processed by the system so that appropriate security controls can be applied. The Business Sensitivity Classification must match the classification in the Data Lifecycle Management (DLM) assessment. Refer to Policy I1-05, Information Classification Policy for additional information.

Select the highest Business Sensitivity Classification for the data processed by this system:	**Highly Restricted**

Process X

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized



SRC will be a type of Event and the nice thing about this is you will be able to select from drop downs so less typos and incomplete information

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | STAGE - Events | Search

Events | Asset | Search

Number	Event Type	State	Asset	Short description	Assignment group	
EVE0001166	SRC	Cancelled	(empty)	ATT testing for cancelling event in triage	USDM Users 1	
EVE0001004	DLM	Cancelled	(empty)	Atkinson DLM Shell	(empty)	
EVE0001088	Data Change	Cancelled	(empty)	ATT Test for Unify Coordinator	USDM ATT Test	
EVE0001002	SRC	Triage	(empty)	SRC Test	(empty)	
EVE0001100	Emergency Change	Closed	(empty)	ATT Testing for event cancellation in Planning state	USDM Users 1	
EVE0001254	DLM	Closed	(empty)	DLM for system	USDM	
EVE0001938	DLM	In Progress	(empty)	DLM for TC2831 Event2		
EVE0001625	DLM	In Progress	(empty)	DLM for AUG4Test		
EVE0001844	DLM	In Progress	(empty)	DLM for Testing Again	(empty)	
EVE0001782	DLM	Planning	(empty)	DLM for Retest3381	(empty)	
EVE0001044	Data Change	In Progress	(empty)	Data Change - SOX Applicable	(empty)	
EVE0001091	Data Change	Cancelled	(empty)	ATT Test for Unify Coordinator	USDM ATT Test	USDMATT User
TMPL-0001016	Standard Change Template	In Progress	(empty)	Chris M- STD Test 6	BTS-Global-ProcessX-SQA Leads	(empty)
EVE0001971	DLM	Triage	(empty)	DLM for NewATT0024	USDM ATT Test	USDMATT User
EVE0001519	DLM	Planning	(empty)	DLM for Non-CMDB Test for 132	(empty)	Laura Blye
EVE0001228	Data Change	Triage	(empty)	Short Desc for ATT Data Change Flow	USDM ATT Test	USDMATT User
EVE0001792	DLM	In Progress	(empty)	DLM for NewATT0022	USDM ATT Test	USDMATT User
TMPL-0001031	Standard Change Template	Planning	(empty)	Testing Template Creation from Create Template	USDM ATT Test	USDMATT User
EVE0001719	DLM	In Progress	(empty)	DLM for NewATT008	USDM ATT Test	USDMATT User
EVE0001055	Data Change	In Progress	(empty)	test dc	(empty)	USDMATT User

Once to start the SRC, you find it and then click on the link to add the details

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | STAGE - STAGE - Events | Search

Event
EVE0001978 View: SRC

Discuss | Follow | Event Audit Report | Save | Review Event Plan | Cancel Event | Close Eve

Open ✓ | Triage

Number	EVE0001978	State	Triage
Reported By	Annamaria Lambidis	Version Status	Draft
Reported Date	2024-09-06 14:53:28	Version	1
* Owning Site	US-IL-Waukegan-J46	* Event Type	SRC
* Asset	ANI LATAM - Salesforce Consumer	Assignment group	
		* Assigned to	Annamaria Lambidis
* Short description	SRC for ANI LATAM - Salesforce Consumer		
Description	Anna training		

These Description fields are different than the System Description and the Intended Use. This is about the actual Event.

Initiation Details | Notes and Activities | Attachments

Created	2024-09-06 15:10:13	Created by	LAMBIAN1

Event Audit Report | Save | Review Event Plan | Cancel Event | Close Event

Related Links

Clone Event

Related Events | Versions (1)

Number | Search | New

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Event - EVE0001978 | Search

Event EVE0001978 View: SRC | Discuss | Follow | Event Audit Report | Save | Start Work

Number	EVE0001978	State	Planning
Reported By	Annamaria Lambidis	Version Status	Draft
Reported Date	2024-09-06 14:53:28	Version	1
* Owning Site	US-IL-Waukegan-J46	Event Type	SRC
Asset	ANI LATAM - Salesforce Consumer	Record ID	SRC0000103
		Assignment group	
		* Assigned to	Annamaria Lambidis
* Short description	SRC for ANI LATAM - Salesforce Consumer		
Description	Anna training		

Initiation Details | Notes and Activities | Attachments

Created	2024-09-06 15:10:13	Created by	LAMBIAN1

Event Audit Report | Save | Start Work | Cancel Event

Related Links

Clone Event

Plan Steps (6) | Related Events | Versions (1)

Order | Search | Actions on selected rows... | New

Event = EVE0001978

Step Name	Order	Assignment Group	Assigned To	Due in Days
SRC Assessment	1	(empty)	Annamaria Lambidis	30

You start the SRC Assessment

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Assessment - RAA0001339 | Search

Task Information
RAA0001339 View: SRC Assessment

Discuss | Follow | Complete | Save | Start Work

Number: RAA0001339
Step Name: SRC Assessment
Event: EVE0001979
State: Open
ment group
Annamaria Lambidis
2024-10-06 20:31:22

Complete the intended use, just like the paper template

Some of this information will be pulled from the CMDB, such as the System Description

System Information

Asset: AN SG Estore
App ID: 13897
System Description: Abbott's direct to consumer e-comm ore for domestic Singapore.
The webshop utilizes the Ma ngurable commercial off the shelf (C-COTS) system for both front end and back end. Product fulfillment is being provided outside of this application.
Intended Use: Intended Use for ProcessX Testing

Most Severe Consequence of Failure

Failure Type: Quality Function Failure
Failure Consequence Description: test

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | Notes and Activities

IT Support Owner: Sanjay Nair
Business Owner: Gautam Balraj Narang
Owning BU Division: AN-Abbott Nutrition

Complete | Save | Start Work

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

The different TABS will walk you through the process

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | Notes and Activities

SLC: BTS (BTSQC09.05)

SLC Repository: M-Files

SQA Responsibility: BTS

Complete | Save | Start Work

Related Links

Extension Request

These options are just like the paper template

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | Systen | nd Activities

System Type: Application

Application Type (Complexity): Customized COTS

Internet Facing: Yes

Hosting Type: Cloud: PaaS

Complete | Save | Start Work

Related Links

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Assessment - RAA0001339 | Search

Task Information
RAA0001339 View: SRC Assessment

Complete | Save | Start Work

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessmen | es and Activities

1. Does the system support **Quality Management**? (AQ01.A)
   a. Does the application or system affect regulatory submission/registration?
   b. Does the application or system perform calculations/algorithms that will support a regulatory submission/registration?
   c. Does the application or system produce, gather or report information used to support Quality System decisions (e.g., metrics, trending, etc.)?
   d. Does the system support processes to establish Quality System, management responsibilities and authority, quality planning, quality audits, management reviews and continuous improvement of the Quality System?

Quality Management: Yes

* Quality Management Comments: test

2. Does the system support **Personnel**? (AQ02.A)
   a. Does the application or system maintain training requirements and/or records?
   b. Does the system maintain personnel qualifications?
   c. Does the system control access to quality systems? (i.e., ESAM)

Personnel: No

3. Does the system support **Nonconformance** (AQ03A.A) and **Corrective Action & Preventive Action (CAPA)**? (AQ03.A)
   a. Does the application or system maintain records of product conformance or nonconformance to acceptance criteria throughout its distribution and lifecycle?
   b. Does the application or system maintain records for the analysis, investigation, verification, and implementation of corrective or preventative actions?

Non-Conformance and CAPA: No

4. Does the system support **Complaints & Product Actions**? (AQ04.A)
   a. Is the application or system used for collecting, monitoring, signaling, assessing and evaluating adverse effects information from healthcare providers and patients (i.e., pharmacovigilance)?
   b. Does the application or system maintain records and/or approvals addressing the identification, evaluation, segregation or disposition of nonconforming products?
   c. Can the application or system be used for product/sample recall, reconciliation, product history, or product-related customer complaints?
   d. Does the application or system maintain records of the initiation, review, evaluation or investigation of complaints?

Complaints and Product Actions: No

These are the same exact questions as in the paper template.

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Assessment - RAA0001339 | Search

Task Information
RAA0001339 View: SRC Assessment

Discuss | Follow | Complete | Save | Start Work

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | Notes and Activities

What is the system impact on patient, personnel, public and/or product safety, product quality, efficacy, and/or performance? (Direct, Indirect, or None)

System Impact: Direct

System Impact Comment: test

If the system has quality **data** that is analyzed, retrieved, manipulated, stored, reported and/or maintained, is there impact that can affect patient, personnel, public and/or product safety, product quality, efficacy, and/or performance? given to missing, incorrect or changed data where it may result in an inappropriate decision or action. (Direct, Indirect, or None)

Data Impact: Direct

Data Impact Comment: test

Does the system have: Functionality that provides for compliance with governmental regulations not classified as "critical" above, and/or Records stored in this system required to meet regulatory requirements?

Regulatory Compliance Support: No

Complete | Save | Start Work

Related Links

Extension Request

These are the same exact questions as on the paper

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Assessment - RAA0001339 | Search

Task Information
RAA0001339 View: SRC Assessment

Discuss | Follow | Complete | Save | Start Work

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | Notes and Activities

These are the same exact questions as on the paper.

Personal Information

Does the system contain any PII (Personally Identifiable Information)?

PII: Yes

If Yes, describe/List the most sensitive data. (For example: patient health data, customer contact information, employee performance data, etc.)

* Personal Information Description: test

* Privacy Sensitivity Classification: Highly Restricted

GDPR

What is the intended geographic scope of the personal information? (Where do the data subjects reside? For example, European Union, United States, Brazil, China, Russia, Global, etc.)

* Intended Geographic Scope of Personal Information: Nepal

* GDPR: Yes

Payment Card Industry (PCI)

a. The Risk Level associated with PCI is "Critical". If the system is involved in storing or transferring the payment card user-session to a 3rd party during checkout - the system affects the overall security of the transaction and is in scope for PCI. See CFM 0075 Payment Card Industry (PCI) or 4-035 IT Payment Card Industry Compliance (PCI) for more information. Any system Regulated for PCI is regulated for Privacy.
b. Does the system facilitate, store or process payment card information?

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

Abbott | All | Favorites | History | Project Workspace | Assessment - RAA0001339 | Search

Task Information
RAA0001339 View: SRC Assessment

Discuss | Follow | Complete | Save | Start Work

Failure Type: Quality Function Failure

Failure Consequence Description: test

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Clas

Regulation

PCI (Payment Card Industry) Information: Yes

HIPAA: Yes

SOX: Yes

Other Regulation:

Classification

GxP Risk Classifi Critical

Privacy Sensitivity Classification: Highly Restricted

System Classification: Regulated

Complete | Save | Start Work

Related Links

Extension Request

This is a nice summary view of the overall ratings for section.

SYSTEM RISK CLASSIFICATION

How SRC will be Digitized

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | No

Business Sensitivity

Systems that contain Structured Data must identify the Business Sensitivity Classification of the data processed by the system so that appropriate security controls can be applied. The Business Sensitivity Classificati
Management (DLM) assessment. A DLM Assessment for the system must be completed before the current SRC Assessment may be completed. Refer to Policy I1-05, Information Classification Policy for additional in

Business Sensitivity Classification: Highly Restricted

Data Sensitivity

The Data Sensitivity Classification is the highest level between the Privacy Sensitivity Classification and the Business Sensitivity Classification.

Data Sensitivity Classification: Highly Restricted

Complete | Save | Start Work

Related Links

Extension Request

This is to help identify the type of data that is maintained in the system that will help guide if a Data Protection Plan is required and the level of cybersecurity that needs to be applied

How SRC will be Digitized

System Responsiblity | SLC | Technical Information | Quality System Regulatory Assessment | GxP Risk Criticality | Non-GxP Regulatory Assessment | System Classification Summary | Sensitivity Classification | Notes and Activities

Activities: 1

AL Annamaria Lambidis — Field changes • 2024-09-06 15:31:22

App ID	13897
App Status	Active
Application Type (Complexity)	Customized COTS
Approval	Not Yet Requested
Assigned to	Annamaria Lambidis
Buildings, Facilities and Utilities	No
Business Owner	Gautam Balraj Narang
Business Sensitivity Classification	Highly Restricted
Clinical Research	No
Complaints and Product Actions	No
Data Impact	Direct
Data Impact Comment	test
Data Sensitivity Classification	Highly Restricted
Distribution, Installation and Servicing Controls	No
Documentation and Change Control	No
Due date	2024-10-06 20:31:22
Equipment	No
Event	EVE0001979
Failure Consequence Description	test
Failure Type	Quality Function Failure

This is a screenshot to show that digitizing allows a view of the audit trail and who changed what

System Risk Assessment Process: Points of Emphasis

SYSTEM RISK CLASSIFICATION

What is a System Risk Classification?

- The System Risk Classification (SRC) is a questionnaire to identify the risk of the overall system in order to be able to evaluate how much risk should be applied to each user and functional requirements
- Consistent use of the System Risk Assessment ensures that all systems are evaluated to consider and incorporate the appropriate regulatory requirements and control the overall risk of the system at the early stages of a project or development lifecycle.
- The SRC also allows for any SME such as privacy or SOX experts to weigh in on any specific regulatory requirements that might apply.
- Transitioning to the ProcessX digital process should be relatively seamless.

Reference Information

System Risk Classification

The System Risk Classification can be found in M-Files or Windchill or possibly other Document Management Systems.

For more information on how SRC is completed see the BTSQC09.05 Software Lifecycle process.

For more information on the SRC, please go to [BTS-SLC - Home (sharepoint.com)](#).

Proprietary and confidential — do not distribute

life. to the fullest.®

Abbott